

Raport incydentu bezpieczeństwa

Atak typu Brute Force na konto użytkownika

Wykrywanie i analiza w środowisku laboratoryjnym (Windows + Sysmon)

ANALITYK	Bartłomiej Kapała
TECHNIKA	MITRE ATT&CK T1110.001 (Password Guessing)
DATA INCYDENTU	17.08.2026

1. Metryka incydentu

Analityk	Bartłomiej Kapała
Typ incydentu	Brute Force — zgadywanie hasła (Password Guessing)
System dotknięty	WIN11 (Windows 11)
Konto docelowe	testuser (konto testowe, lokalne)
Data i czas	17.08.2026, 19:00:07–19:01:10 (UTC lokalny maszyny)
Źródło wykrycia	Windows Security Auditing + Sysmon
Klasyfikacja	Ćwiczenie laboratoryjne (kontrolowana symulacja)
Severity	HIGH
Status	Wykryty i przeanalizowany

2. Streszczenie wykonawcze

Dnia 17.08.2026 odnotowano **5 nieudanych prób zalogowania** na konto użytkownika „testuser”. Szósta próba, o godzinie 19:01:10, zakończyła się **powodzeniem** — atakujący uzyskał dostęp do konta poprzez zgadnięcie hasła.

Cały atak trwał **63 sekundy** (19:00:07–19:01:10). Krótki, regularny odstęp między próbami (co ok. 5–10 s) wskazuje na charakter automatyczny lub półautomatyczny, odróżniający atak od przypadkowych pomyłek użytkownika.

Ponieważ atak zakończył się przejęciem konta, sklasyfikowano go jako **HIGH**. W realnym środowisku takie przejęcie stanowiłoby punkt wyjścia do dalszego rozpoznania i ruchu bocznego w sieci.

3. Opis incydentu

Wektor	Brute Force (zgadywanie hasła)
Technika MITRE	T1110.001 — Password Guessing
Taktyka MITRE	Credential Access
Logon Type	2 (interaktywne / lokalne)
Źródło	::1 (localhost — atak lokalny)
Wynik	Atak udany — konto przejęte

Opis: Na koncie „testuser” w systemie WIN11 wystąpiła seria nieudanych prób logowania zakończona udanym dostępem. Wszystkie zdarzenia dotyczą tego samego konta, tego samego typu logowania (2) i pochodzą z adresu pętli zwrotnej (::1), co jednoznacznie wskazuje na **atak lokalny** — przeprowadzony na tej samej maszynie, nie zdalnie przez sieć.

4. Chronologia zdarzeń

Chronologię odtworzono na podstawie dziennika Windows Security (Event Viewer), po odfiltrowaniu zdarzeń 4625/4624 z okna ataku.

#	CZAS (17.08.2026)	EVENT ID	ZDARZENIE
1	19:00:07	4625	Nieudana próba logowania — konto testuser
2	19:00:12	4625	Nieudana próba logowania — konto testuser
3	19:00:17	4625	Nieudana próba logowania — konto testuser
4	19:00:25	4625	Nieudana próba logowania — konto testuser
5	19:01:04	4625	Nieudana próba logowania — konto testuser
6	19:01:10	4624	LOGOWANIE UDANE — konto testuser (hasło zgadnięte)

Interpretacja: pięć kolejnych niepowodzeń (4625) w ciągu ~60 sekund, bezpośrednio po których następuje udane logowanie (4624) na to samo konto, to podręcznikowa sygnatura skutecznego ataku brute force.

5. Analiza techniczna

5.1 Zdarzenia bezpieczeństwa

- Event ID 4625 (An account failed to log on) — zarejestrowano 5-krotnie dla konta testuser.
- Event ID 4624 (An account was successfully logged on) — 1 raz, o 19:01:10, dla konta testuser.
- Failure Reason we wszystkich 4625: „Unknown user name or bad password” — typowy komunikat przy zgadywaniu hasła.

5.2 Typ i źródło logowania

- Logon Type: 2 — logowanie interaktywne (lokalne). Oznacza, że próby wykonano bezpośrednio na maszynie, a nie zdalnie.
- Source Network Address: ::1 — adres pętli zwrotnej IPv6 (localhost), potwierdza charakter lokalny.
- Gdyby atak przyszedł zdalnie (np. przez SMB z innej maszyny), Logon Type wynosiłby 3 (network), a Source Network Address wskazywałby zewnętrzny adres IP. Ich brak potwierdza kontrolowaną symulację lokalną.

5.3 Proces obsługujący

- Caller Process: C:\Windows\System32\svchost.exe — legalny proces hosta usług Windows. Uwierzytelnianie prób obsłużyła usługa systemowa (Secondary Logon) działająca w svchost.
- Lokalizacja procesu (System32) potwierdza, że jest to prawidłowy svchost, a nie podszywający się malware. W analizie realnych incydentów należy weryfikować ścieżkę svchost — atakujący często maskują złośliwe procesy pod tą nazwą.

6. Mapowanie do MITRE ATT&CK

T1110.001 — Brute Force: Password Guessing (taktyka: Credential Access). Technika polega na wielokrotnym zgadywaniu hasła do konta w celu uzyskania nieautoryzowanego dostępu. Obserwowany wzorzec (seria prób na jedno konto) odpowiada tej pod-technice.

Uwaga: technika nadrzędna T1110 (Brute Force) obejmuje też Password Spraying (T1110.003 — jedno hasło na wiele kont) i Credential Stuffing (T1110.004). W tym incydencie mamy do czynienia z Password Guessing, ponieważ atak koncentrował się na jednym koncie z wieloma hasłami.

7. Wskaźniki kompromitacji (IOC)

Wskaźniki odczytane bezpośrednio ze zdarzeń Windows Security.

WSKAŹNIK / POLE	WARTOŚĆ
Konto (cel)	testuser
Event ID (nieudane)	4625 — An account failed to log on
Event ID (udane)	4624 — An account was successfully logged on
Logon Type	2 (logowanie interaktywne / lokalne)
Source Network Address	::1 (adres pętli zwrotnej IPv6 – localhost)
Failure Reason	Unknown user name or bad password

WSKAŹNIK / POLE	WARTOŚĆ
Caller Process	C:\Windows\System32\svchost.exe (legalny host usług)
Maszyna docelowa	WIN11
Wzorzec	5 x 4625 → 1 x 4624 w oknie 63 s (19:00:07–19:01:10)

8. Analiza przyczyn źródłowych (RCA)

Bezpośrednia przyczyna: konto testuser posiadało słabe, łatwe do odgadnięcia hasło, a system nie miał skonfigurowanej blokady konta po serii nieudanych prób (Account Lockout Policy).

Przyczyny systemowe:

- Brak progu blokady konta — atakujący mógł wykonać dowolną liczbę prób bez konsekwencji.
- Słabe hasło konta testowego — umożliwiło zgadnięcie w zaledwie 6 próbach.
- Brak mechanizmu alertowania w czasie rzeczywistym — seria 4625 nie wywołała automatycznego powiadomienia.

9. Działania naprawcze

Natychmiastowe (ograniczenie)

- Zablokowanie/reset przejętego konta testuser i wymuszenie zmiany hasła.
- Weryfikacja, czy po przejęciu konta nie wykonano dalszych działań (przegląd kolejnych zdarzeń dla tego konta).

Krótkoterminowe (eliminacja)

- Ustawienie silnego hasła zgodnego z polityką złożoności.
- Wdrożenie Account Lockout Policy (blokada po serii nieudanych prób).

Długoterminowe (przywracanie / prewencja)

- Wdrożenie MFA dla kont, szczególnie uprzywilejowanych.
- Konfiguracja reguły detekcji w SIEM (patrz sekcja 10).

10. Rekomendacje

10.1 Kontrola prewencyjna — Account Lockout Policy

Konfiguracja blokady konta po serii nieudanych prób logowania. Rekomendowany próg: 5 nieudanych prób w krótkim oknie czasowym (kompromis między bezpieczeństwem a fałszywymi alarmami z pomyłek użytkowników). Zbyt niski próg (np. 3) blokuje użytkowników za literówki; zbyt wysoki daje atakującemu więcej prób.

10.2 Reguła detekcji (SIEM)

Reguła korelacyjna wykrywająca wzorzec brute force:

- **Detekcja:** ≥5 zdarzeń Event ID 4625 dla tego samego konta w oknie 60 sekund → alert „Możliwy atak brute force”.
- **Eskalacja (krytyczna):** jeśli po serii 4625 wystąpi 4624 (sukces) dla tego samego konta → alert „Możliwe przejęcie konta” o podwyższonym priorytecie.

Uwaga analityczna: sam lockout to prewencja (blokuje atak), a reguła SIEM to detekcja (informuje analityka). To dwie uzupełniające się warstwy — lockout może zatrzymać atak, ale zespół SOC i tak powinien otrzymać informację o próbie.

10.3 Pozostałe

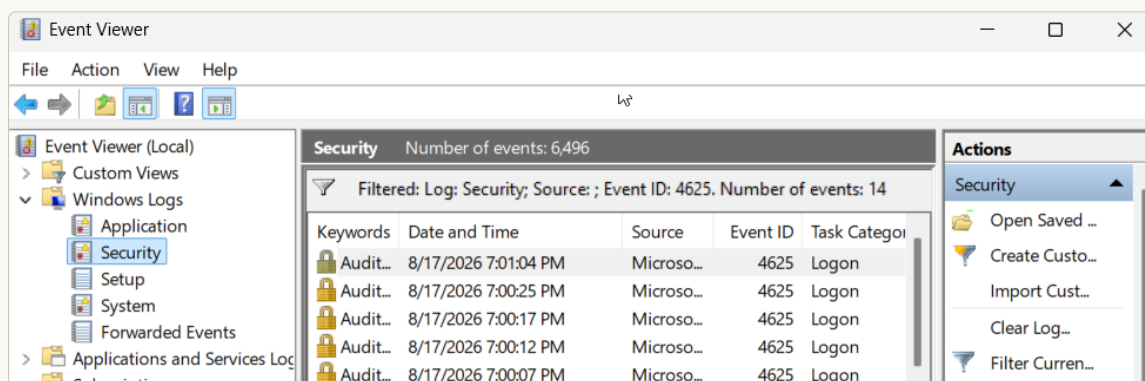
- MFA — nawet zgadnięte hasło nie wystarczy do zalogowania.
- Polityka silnych haseł — wydłuża czas potrzebny na złamanie.
- Monitoring logowań uprzywilejowanych kont w trybie ciągłym.

11. Wnioski i wyciągnięte lekcje

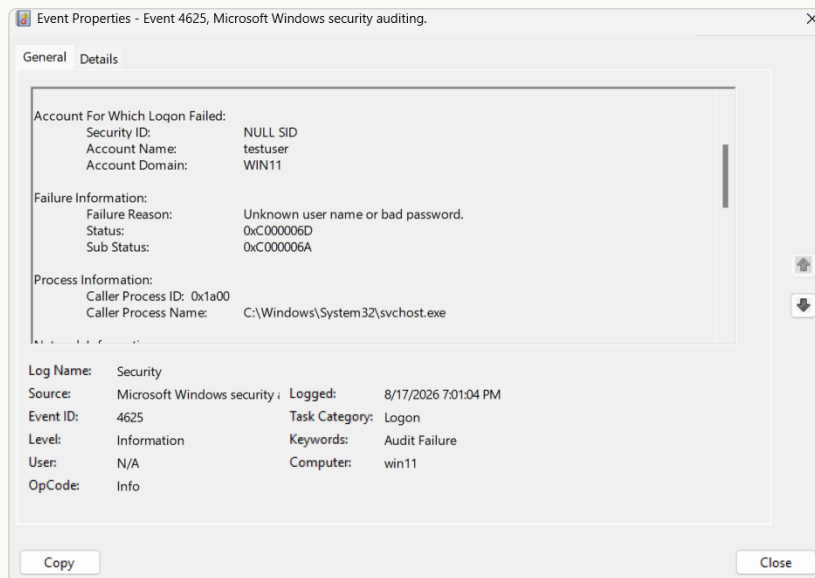
- **Wzorzec detekcji:** seria zdarzeń 4625 zakończona 4624 dla tego samego konta to jednoznaczny sygnał skutecznego brute force. To fundament reguł SIEM dla tej techniki.
- **Logon Type jako wskaźnik wektora:** Type 2 + źródło ::1 wskazują atak lokalny; Type 3 + zewnętrzny IP wskazywałyby atak sieciowy. Analityk rozpoznaje wektor po tych polach.
- **Weryfikacja procesów:** svchost.exe jest legalny tylko z lokalizacji System32 — należy zawsze sprawdzać ścieżkę, bo malware podszywa się pod tę nazwę.
- **Znaczenie widoczności:** bez włączonego audytu logowań (Success/Failure) zdarzenia 4625 nie byłyby rejestrowane — konfiguracja logowania jest warunkiem wykrycia.
- **Troubleshooting środowiska:** nowoczesny Windows 11 (SMB signing, ograniczenia RDP w edycji Home, blokowanie ping) skutecznie utrudnia zdalne ataki narzędziami takimi jak hydra/NetExec — co samo w sobie jest obserwacją obronną.

12. Załączniki / Dowody

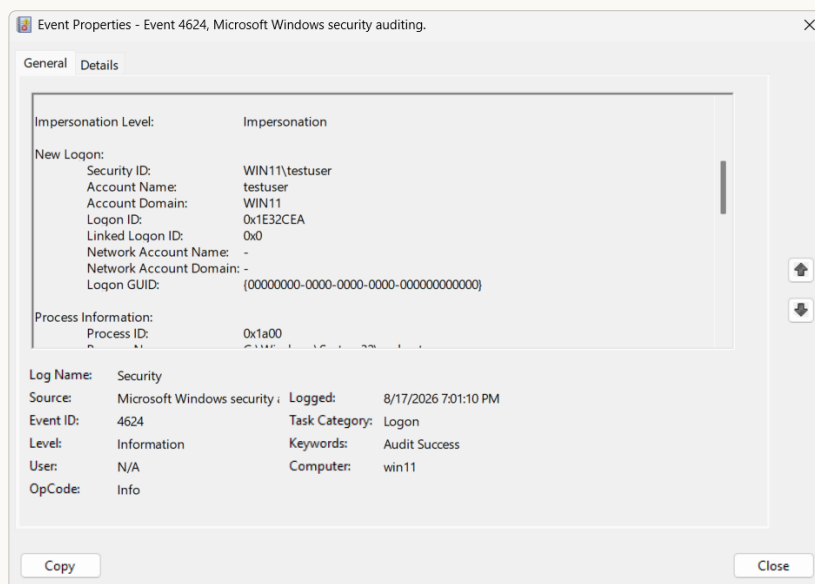
Poniższe materiały stanowią dowód przeprowadzenia analizy oraz przygotowania środowiska detekcji w systemie WIN11. Wszystkie zrzuty pochodzą z dnia incydentu (17.08.2026).



Zař. 1. Event Viewer — przefiltrowany widok zdarzeń 4625 (Event ID 4625, łącznie 14 w dzienniku). Widoczne okno ataku: 19:00:07–19:01:04.



Załącznik 2. Szczegóły zdarzenia 4625 — konto testuser (WIN11), Failure Reason „Unknown user name or bad password”, Caller Process svchost.exe z lokalizacji System32.



Załącznik 3. Szczegóły zdarzenia 4624 (sukces) — WIN11\testuser, godzina 19:01:10, Audit Success. Potwierdzenie przejęcia konta po serii nieudanych prób.

```
PS C:\WINDOWS\system32> auditpol /get /subcategory:"Logon"
System audit policy
Category/Subcategory      Setting
Logon/Logoff
Logon                      Success and Failure
```

Załącznik 4. Konfiguracja audytu logowań (auditpol) — kategoria Logon ustawiona na „Success and Failure”. Konfiguracja aktywna przez cały czas trwania testu.

```
PS C:\WINDOWS\system32> Get-Service Sysmon

Status Name      DisplayName
-----
Running sysmon Sysmon
```

Załącznik 5. Usługa Sysmon w stanie Running — potwierdzenie działającej widoczności endpointa podczas incydentu.

Analiza oparta wyłącznie na zweryfikowanych zdarzeniach z dziennika Windows Security systemu WIN11. Incydent przeprowadzony w kontrolowanym środowisku laboratoryjnym.